



Dr. Ammar Haider
Assistant Professor
School of Computing

CS3002 Information Security



IT Security Management

Security Management



- So far in this course we have learnt a range of technical and administrative measures that can be used to manage and improve the security of information systems.
- But we need a **process** of selecting best measures and implementing them to meet an organization's security need.
- This involves examining three questions:
 1. What assets do we need to protect?
 2. How are those assets threatened?
 3. What can we do to counter those threats?
- IT security management is the **formal process** of answering these questions

Overview of security management processes

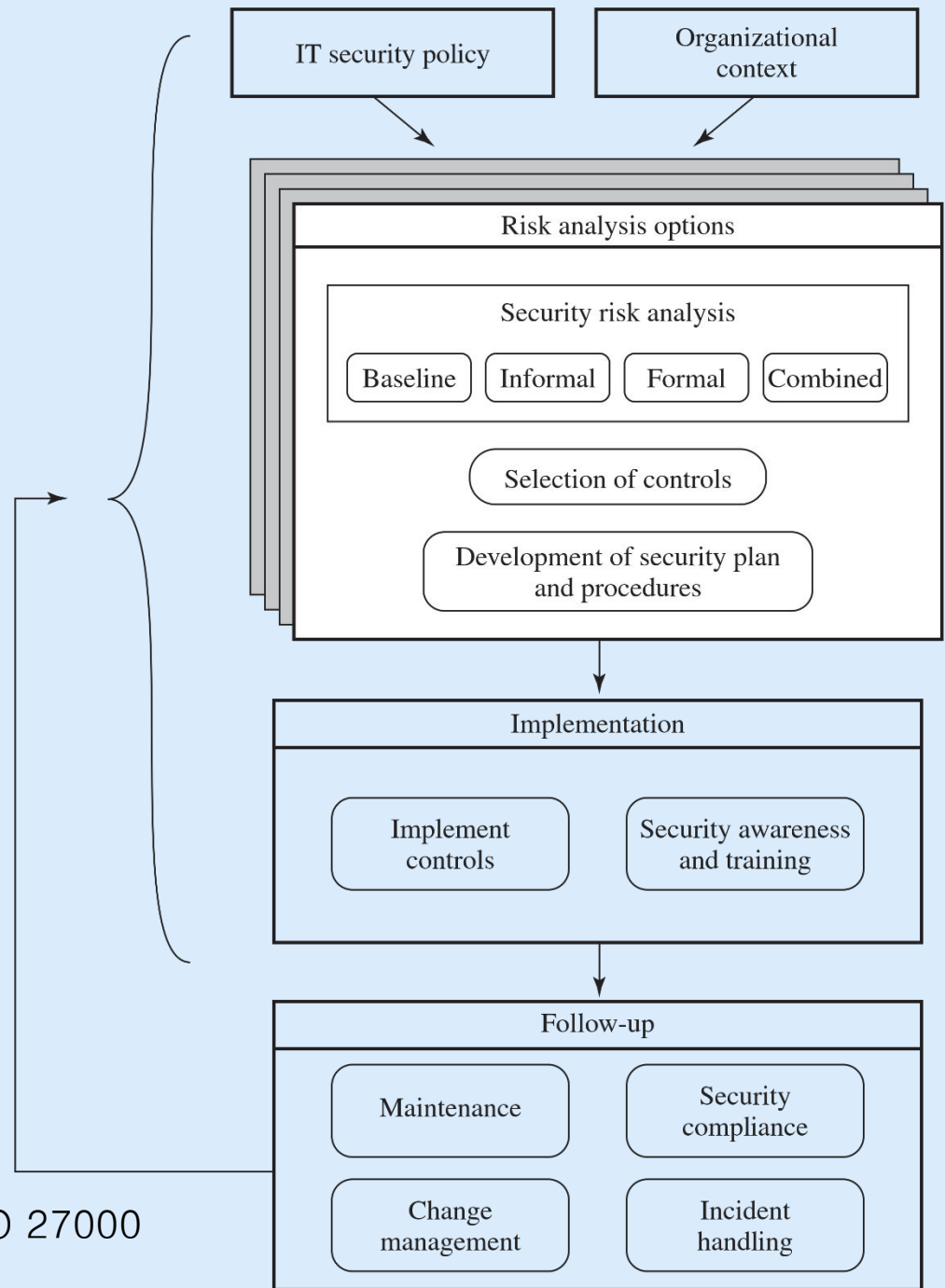


Figure adapted from ISO 27000 series standards



Security Policy



- Organizational security policy describes what the objectives and strategies are and the process used to achieve them.
- It may be either a single large document or, more commonly, a set of related documents.
- It needs to address the following topics
 - Scope and purpose of the policy
 - Relationship of the security objectives to the organization's business objectives, and any legal and regulatory obligations

Security Policy



- IT security requirements in terms of confidentiality, integrity, availability, accountability, authenticity, and reliability.
- Assignment of IT security management responsibilities to company roles
 - e.g. Senior team leader is responsible for so and so.
- Risk management approach adopted
 - baseline, informal, detailed, or combined ('detailed' approach is briefly covered later in this lecture)
- How security awareness and training is to be handled
- Any legal sanctions that may be imposed on staff, and the conditions under which such penalties apply

Security Policy



- Integration of security into systems development and procurement
 - how security will be incorporated when designing in-house software, and when buying new software
- Definition of the information classification scheme used across the organization
 - i.e. define the terms top secret, confidential, restricted etc.
- Contingency and business continuity planning
- Incident detection and handling processes
- How and when this policy should be reviewed
- The method for controlling changes to this policy

Security Policy



- Note: some sources call these kind of documents **security plan**
- Policy is subject to periodic review and revision as the organization's security needs change.
- Various standards recommend that overall responsibility for the organization's IT security be assigned to a single person, the organizational **IT security officer** .

Organizational Context



- At a high level, all organizations have same security goal: to prevent security breaches. But digging deeper, security needs for each organization differ.
- What does an organization consider its most precious asset?
 - A pharmaceutical company might value its scientific research on new drugs and its sales and marketing strategy as its most important assets.
 - A hospital would likely find protecting the confidentiality of its patients' records most crucial, perhaps followed closely by the integrity and availability of its systems that implement patient care (like vitals monitoring systems)
 - A television studio could decide its archive of previous broadcasts is most important.

Risk Management



Why risk management



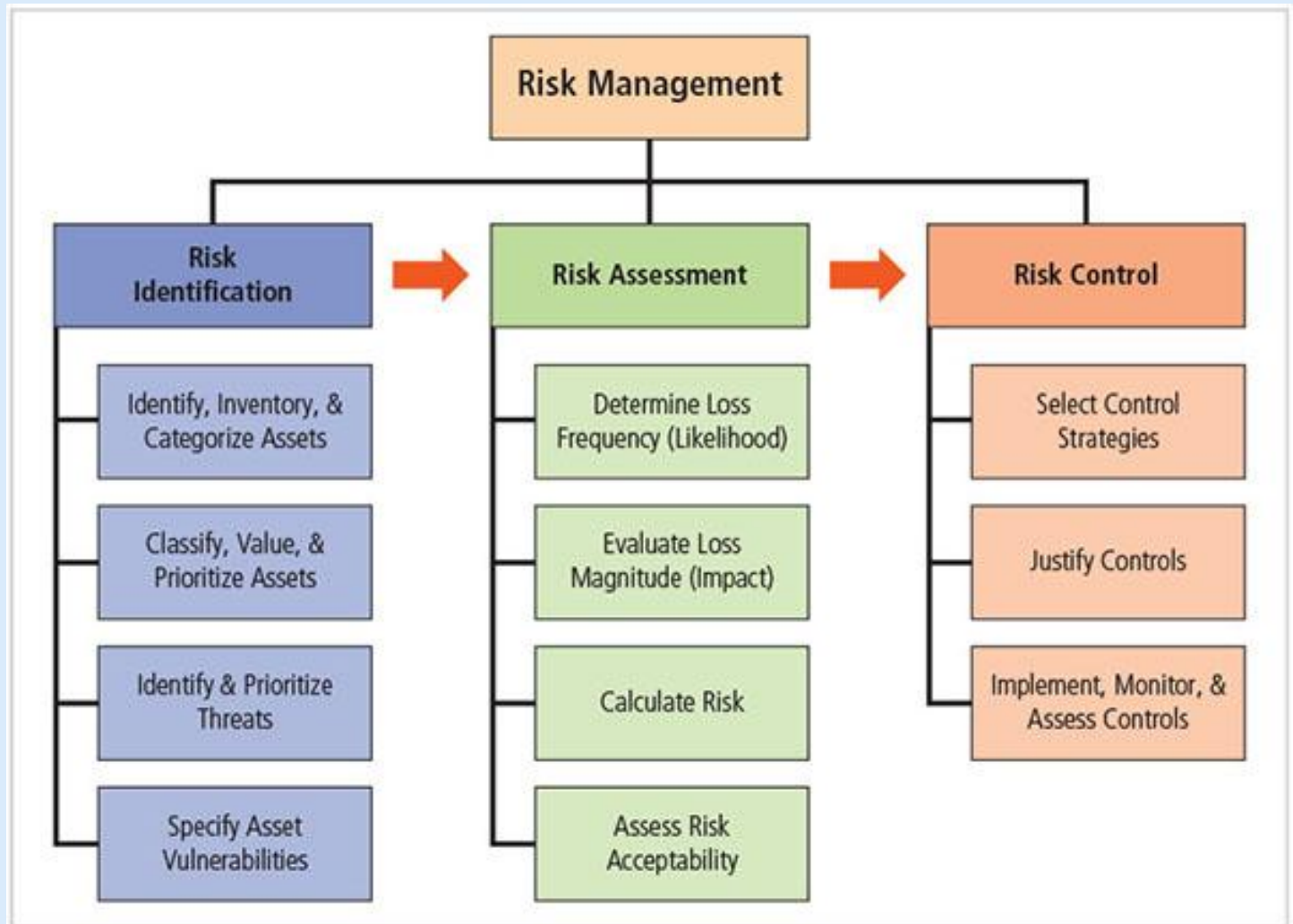
- An organization can't protect everything equally.
- Their resources—time, money, and people—are finite. So they must focus their defenses on what matters most.
- Cybersecurity Risk Management is the process of identifying what is most valuable and most vulnerable, and then making strategic decisions to protect it.
- It's about being smart, not just strong.

Elements of risk assessment



- Risk assessment is formal process to understand your specific cyber risks. It answers three key questions:
- **What are our most important assets?** the “crown jewels” — e.g., customer database, industrial control systems, financial records.
- **What are the threats and vulnerabilities** that could affect those assets?
- **What would be the impact** if something bad happened?
- Note that a business should consider all kinds of risks during their assessment, not just IT security issues.
 - Here we are only focusing on the latter.

Risk Management



Identifying Assets



Assets can be grouped into few categories.

- **Hardware:** servers, client workstations, printers, portable devices, network equipment (routers, switches) etc.
- **Software:** source code, binary executables, operating systems, systems software (compiler etc.), maintenance and diagnostic software
- **Data:** data in memory, on permanent media, in cloud, printed data, audit logs
- **People:** skilled staff needed to run the systems
- **Supplies:** paper, data storage devices, printer ink, electricity, heating and cooling, necessary buildings

Identifying Assets



- **Documentation:** on programs, hardware, systems, administrative procedures, and the entire system
- **Reputation:** company image, goodwill with customers and business partners
- **Availability:** ability to do business, ability to resume business rapidly and efficiently after an incident
- You **must** tailor this list to your own situation. No two organizations will have the same assets to protect, and something that is valued by one organization may not have the same value to another.

Identify Threats to Assets



- Threats can also be grouped in a several categories
- Each type of asset is subject to different type of threats

Asset	Secrecy	Integrity	Availability
Hardware		overloaded destroyed tampered with	failed stolen destroyed unavailable
Software	stolen copied pirated	impaired by Trojan horse modified tampered with	deleted misplaced usage expired
Data	disclosed accessed by outsider inferred	damaged • software error • hardware error • user error	deleted misplaced destroyed
People			quit retired terminated on vacation
Documentation			lost stolen destroyed
Supplies			lost stolen damaged

Note: this table only shows TYPES of assets and threats.

An organization will make list of actual assets and their corresponding actual threats.

Risk Likelihood



- Likelihood indicates the chances that the organization will have to face a specific threat
- Could be expressed either
 - on a qualitative scale like low, moderate high or
 - as a probability number between 0 and 1.
Unfortunately, it is often extremely hard to determine accurate probabilities
- Can be estimated from organization's history or published studies

Loss Magnitude (Impact)



- How much is the effect on organization's business when threat occurs
- Again, can be expressed either way
 - qualitatively as low, moderate, high or as a number on an arbitrary scale (say 1–10)
 - quantitatively as actual financial loss measured in monetary value. e.g. \$20,000 revenue loss due to downtime of 5 minutes. But in many cases, exact loss figure is also very hard to estimate.

Calculate Risk Score



Risk score = Likelihood of threat × Threat impact

- Score gives us a measure of prioritizing the risks.
- Risk matrix (aka risk register) is a tool for visualizing all risks. **Focus your resources on the red zone first!**

			Impact			
			0 Acceptable	1 Tolerable	2 Unacceptable	3 Intolerable
			Little or No Effect	Effects are Felt but Not Critical	Serious Impact to Course of Action and Outcome	Could Result in Disasters
Likelihood	Improbable	Risk Unlikely to Occur				
	Possible	Risk Will Likely Occur				
	Probable	Risk Will Occur				

Risk Treatment (Controls)



- Once all the threats and their scores have been documented, its time to decide what are we going to do about each.
- There are four control strategies
 - Transference
 - Acceptance
 - Avoidance
 - Defense / Mitigation

Transference



- Shift risk to other assets, processes, or organizations

Examples

- Outsourcing site hosting to a cloud service provider
 - Purchasing insurance against ransomware attacks
 - Signing service contracts with a vendor
-
- Concentrate on what you do best

Acceptance



- Understand the consequences and **do nothing** to protect a vulnerability
 - Accept the outcome of its exploitation
- Valid only when the particular function, service, information, or asset does not justify the cost of protection
- ‘Risk appetite’ describes the degree to which organization is willing to accept risk as trade-off to the expense of applying controls

Avoidance



- Avoid business activities that introduce an uncontrollable risk
- This usually results in loss of convenience or inability to perform some useful function.
- The loss of this capability is traded off against the reduced risk profile.

Example

- A personal finance & budgeting app decides not to integrate with users' bank accounts – due to risk of unauthorized transactions if app is hacked.

Defense / Mitigation



- Apply safeguards that either
 - reduce the likelihood of threat occurrence
 - or
 - lessen the impact should the vulnerability be exploited.
- Mitigation will reduce the risk score to a smaller value (called ‘residual risk’)

Examples

- Regularly update software to remove vulnerabilities
- Enforce access control on files and databases
- Set up an intrusion detection systems

Contingency Planning



When bad things do happen



- No defense is 100% perfect. A security incident will eventually occur.
- Our goal should be to minimize the damage and recover as quickly as possible.
- *Failing to plan is planning to fail.*
- **Incident response plan** tells the staff how to deal with a security incident.
- It covers identification and classification of an incident and appropriate response to it.
- Incident response (IR) is more reactive, than proactive, except for planning that must occur to prepare IR teams to be ready to react to an incident

Incident Response Planning



Attacks classified as incidents if they:

- are directed against information assets
 - have a realistic chance of success
 - could threaten confidentiality, integrity, or availability of information resources
-
- In planning, we develop a series of predefined responses
 - Set of activities taken to detect and correct the impact
 - Enables organization to react quickly and correctly instead of everyone being confused in heat of the moment.

Incident Response Plans (IRP)



- IRP documents define the actions of each person (role) who must help the organization react to and recover from the incident.
- The documents list
 - Who is on the Incident Response Team? (IT, Legal, HR, Communications, Leadership).
 - Who has the authority to make critical decisions? (e.g., shutting down a system).
 - How do you communicate internally and externally? (To employees, the public, and regulators).
- IRPs must also be tested in (say) a simulated scenario to ensure they are effective.

Incident Detection



Sources of Incident detection – intrusion detection systems, anti malware software, system administrators, end users.

- **Possible indicators:** Presence of unfamiliar files, execution of unknown processes, unusual consumption of resources, unusual system crashes
- **Probable indicators:** Activities at unexpected times, presence of new accounts, reported attacks, notification from IDS
- **Definite indicators:** Use of dormant accounts, changes to logs, presence of hacker tools, notification by hackers

Incident Reaction



- Once IRP is activated, the designated staff must follow the actions outlined in it.
- Purpose is to
 - Stop the incident
 - Mitigate the impact
 - Provide information recovery
- Immediately when incident is discovered, we must notify the key personnel (as specified in the IRP)
- Documenting the incident is also an important action: note down the **who, what, when, where, why, and how** of the events
- Next step is to contain the incident

Incident Containment Strategies



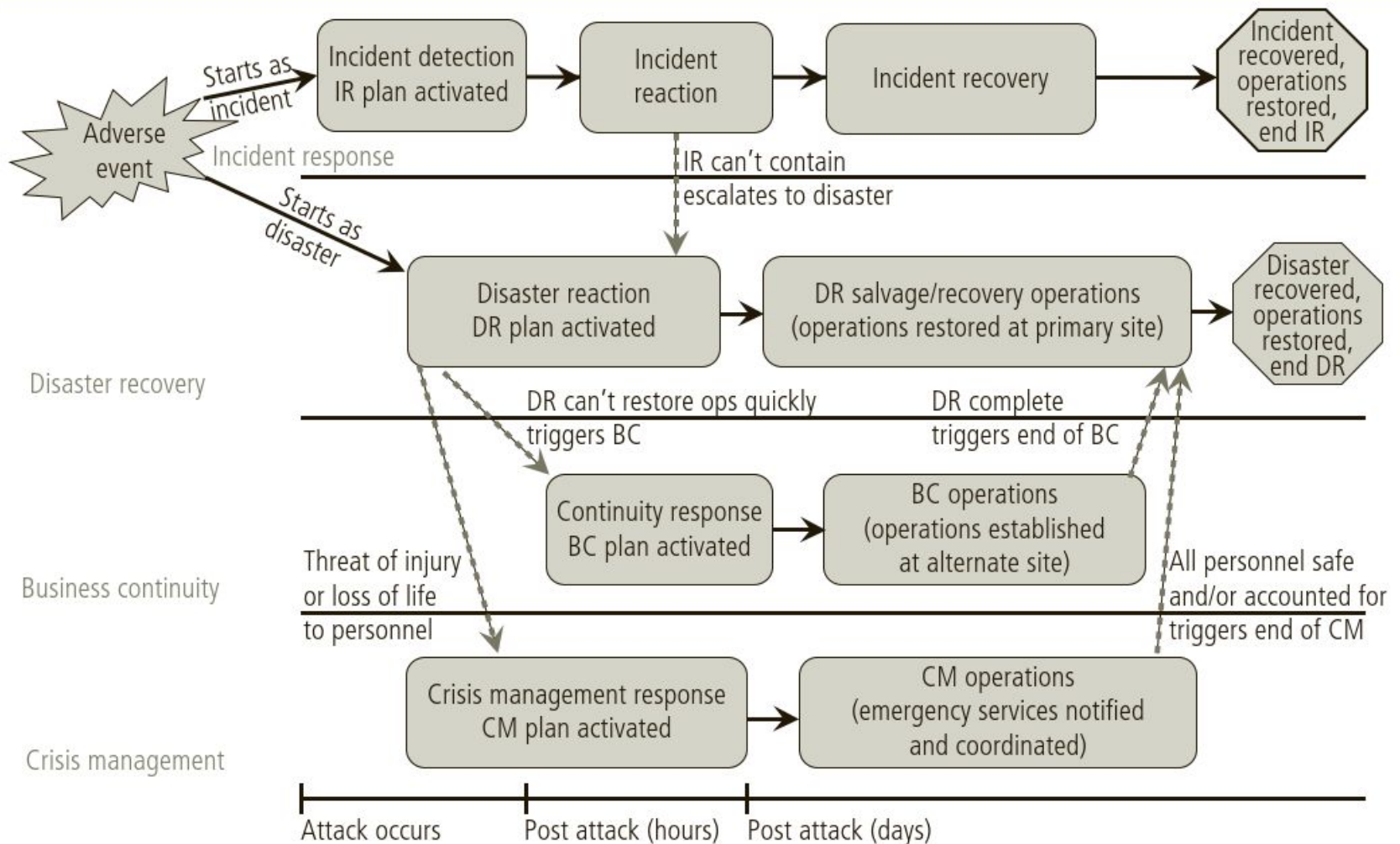
- Sever affected communication circuits if possible
 - keeping disruption to business activities minimum
- Disable accounts
- Reconfigure firewall
- Disable process or service
- Take down email
- Isolate affected channels, processes, services, or computers
- Most drastic: Stop all computers and network devices

Incident Recovery



- Assess full extent of the damage
- Conduct 'forensic' activities to determine how the incident occurred and what happened.
- Based on results of forensic analysis
 - Identify and resolve vulnerabilities
 - Address safeguards
 - Evaluate monitoring capabilities
- Restore data from backups
- Restore process and services
- Continuously monitor system

Contingency Planning Timeline



Disaster Recovery Plan (DRP)



- An event can be categorized as a disaster when an organization is unable to mitigate the impact of an incident while it is occurring and the level of damage or destruction is so severe that the organization is unable to recover quickly.
- The Disaster Recovery Plan is similar in structure to the IR plan, provides detailed guidance in the event of a disaster.
- It is organized by the type or nature of the disaster, and it specifies recovery procedures during and after each type of disaster.

Disaster Recovery Plan (DRP)



- **Aim** : Secure most valuable assets, at the risk of short-term disruption.

What it contains

- Clear establishment of priorities
 - e.g. human life is most important
 - After that, note down which services are most important to safeguard
- Clear delegation of roles & responsibilities
- Document disaster events
- Mitigate impact if possible
- Evacuation of physical assets

Business Continuity Plan (BCP)



- **Aim** : reestablish or relocate critical business operations during a disaster
- If a disaster has rendered the primary location unusable, a plan must be in place to allow the business to continue to function at an alternate location (if possible).

What it contains

- The most critical hardware/software to be restored on- or off-site
- Retrieving backups
- Personnel responsible for each action

References



- Stalling SPP chap 14, 15
- Whitman chap. 4
- Pfleeger, Security in Computing, chap 10